

Digital Policy Office

INFORMATION SECURITY

Practice Guide for Security Controls on Virtualisation

Version 1.1

July 2024

© The Government of the Hong Kong Special Administrative Region
of the People's Republic of China

The contents of this document remain the property of and may not be reproduced in whole or in part without the express permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China.

COPYRIGHT NOTICE

© 2024 by the Government of the Hong Kong Special Administrative Region of the People's Republic of China

Unless otherwise indicated, the copyright in the works contained in this publication is owned by the Government of the Hong Kong Special Administrative Region of the People's Republic of China. You may generally copy and distribute these materials in any format or medium provided the following conditions are met –

- (a) the particular item has not been specifically indicated to be excluded and is therefore not to be copied or distributed;
- (b) the copying is not done for the purpose of creating copies for sale;
- (c) the materials must be reproduced accurately and must not be used in a misleading context; and
- (d) the copies shall be accompanied by the words “copied/distributed with the permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China. All rights reserved.”

If you wish to make copies for purposes other than that permitted above, you should seek permission by contacting the Digital Policy Office.

Amendment History				
Change Number	Revision Description	Pages Affected	Revision Number	Date
1	Change “Office of the Government Chief Information Officer” (or “OGCIO”) to “Digital Policy Office” (or “DPO”)		1.1	July 2024

Table of Contents

1.	Introduction.....	1
1.1	Purpose.....	1
1.2	Normative References.....	1
1.3	Terms and Convention.....	2
1.4	Contact	3
2.	Planning, Installation and Configuration.....	4
3.	Vulnerability and Policy Management	6
4.	Intrusion Prevention and Protection	8
5.	Identity and Access Management.....	9
6.	Network Access Control.....	10
7.	Monitor and Audit.....	11

1. Introduction

Virtualisation in this document refers to the technology of creating and managing one or more virtual machines (VMs) used for IT development, testing or operation. A VM could be served as a workstation, a server, a storage device or other network resource. In virtualisation, a software layer, which is used to simulate one or more instances of VMs running on a "real" machine, is called Virtual Machine Monitor (VMM) or hypervisor.

A VMM allows sharing of the underlying physical hardware resources between different VMs. There are two types of VMM: Type 1 (native or bare-metal) hypervisor and Type 2 (or hosted) hypervisor. The former is built like an operating system which can run directly on the hardware, the latter runs as an application on top of an existing (or host) operating system. The VM running on top of the host operating system (host OS) is called the guest operating system (guest OS).

1.1 Purpose

As virtualised environments are not inherently secure, security controls should be well considered from planning to implementation stage. This document provides a list of items to protect a virtualised environment.

- Planning, Installation and Configuration
- Vulnerability and Policy Management
- Intrusion Prevention and Protection
- Identity and Access Management
- Network Access Control
- Monitor and Audit

1.2 Normative References

The following referenced documents are indispensable for the application of this document.

- Addressing security vulnerability issues in a virtualized environment, Vilquin, P., 2008
- <http://www.networksasia.net/article/addressing-security-vulnerability-issues-virtualized-environment-1226363580> ESX Server Security Technical Implementation Guide, DISA Field Security Operations, DISA, 2008
http://iase.disa.mil/stigs/stig/esx_server_stig_v1r1_final.pdf
- How Virtualization Affects PCI DSS Part 2: A Review of the Top 5 Issues, Hau W., et al, n.d., McAfee
<http://docplayer.net/7978256-How-virtualization-affects-pci-dss.html>

- Limited Choices Are Available for Network Firewalls in Virtualized Servers, Gartner, 2007
<https://www.gartner.com/doc/569009/limited-choices-available-network-firewalls>
- Security Considerations and Best Practices for Securing Virtual Machines, MacDonald N., Gartner, 2007
<https://www.gartner.com/doc/501995/security-considerations-best-practices-securing>
- Security in Operating System Virtualisation, the Government of the HKSAR, 2008
<http://www.infosec.gov.hk/english/technical/files/security.pdf>
- Virtualization and Next-Generation Data Centers, Moore, H., 2009
<http://www.drdoobs.com/parallel/virtualization-and-next-generation-data/213000105?pgno=2>
- When Virtual is Harder than Real: Security Challenges in Virtual Machine Based Computing Environments, Garfinkel, T., et al, Stanford University Department of Computer Science, 2005
http://www.usenix.org/event/hotos05/final_papers/full_papers/garfinkel/garfinkel.pdf

1.3 Terms and Convention

For the purposes of this document, the terms and convention given in S17, G3, and the following apply.

Abbreviation and Terms	
NA	NA

1.4 Contact

This document is produced and maintained by the Digital Policy Office (DPO). For comments or suggestions, please send to :

Email: it_security@digitalpolicy.gov.hk

Lotus Notes mail: IT Security Team/DPO/HKSARG@DPO

CMMP mail: IT Security Team/DPO

2. Planning, Installation and Configuration

The process of securing VMs starts before they are deployed so that security can be factored into the evaluation and selection process.

- a) **Assess potential risks.** It should be performed as part of the risk management process before vendors/products are selected. Before implementing virtualisation, the potential risk should be assessed comparing with options without virtualisation.
- b) **Keep the host OS thin and hardened.** To reduce the surface area for being attacked and the need for patching, OS with minimum required functions should be used. The installed host OS shall be as thin and hardened as possible to lower the ability to load arbitrary software. Type 1 VMM often provides a more compact and secure host OS.
- c) **Use processors that natively support virtualisation.** Some microprocessors are designed to utilise resources and provide better performance for virtualisation. These processors are capable to ensure guest OSs running at a lower privilege than the VMM for better security and performance.
- d) **Manage the virtualised environment through VMM management utilities.** Moving most of the security and management functions (e.g. firewall, virus scanning, backup) of guest OSs into a co-existing layer (i.e. VMM) that allows centralised administration. This also permits auto-failover or other actions if some VMs are offline, improving the usability, scalability and transience.
- e) **Deploy replication and high availability technologies.** It allows clustering on host machines to compensate for single point of failure. For example, losing power on a host machine may cause impact to several VMs. It is essential to monitor all servers in a resource pool and detect failures. In the event of server failure, affected VMs could be automatically restarted on cluster nodes.
- f) **Review the sharing of resources.** When resources are shared and locked by alternating VMs, problems may occur. To avoid resource contention, the applications and services on a host computer shall be well-planned and reviewed.
- g) **Review the resources requirement of applications.** If any guest application has periodic high demands on resources, capacity planning is required to allocate time slot and dynamic resource so that other applications will not be "locked out" by resource contentions.
- h) **Enforce the principle of least privilege.** Two VMs should never directly communicate with each other (including disk blocks or LAN resources) unless explicitly permitted. This reduces the risk of a compromised VM that could intercept the traffic and compromise the data or system of other VMs.
- i) **Avoid using shared IP addresses.** Since most security and management tools do not support VMs behind network address translation (NAT) configurations,

problems may occur with shared IP addresses without monitoring. Alternatively, virtual media access control (MAC) address can be assigned to each virtual network adapter which can be assigned with an external valid IP address.

- j) **Separate critical and non-critical systems.** Mission critical systems are not recommended to co-exist with other non-critical systems under the same virtualised environment. Internal virtual LAN (VLAN) capabilities should not be used as the sole means of separating different trust levels. Furthermore, VLANs do not provide security policy enforcement for separating security zones between trusted and un-trusted networks.
- k) **Maintain inventory record.** Clear documentation is required to record the virtualised environment deployed. As some network components (e.g. virtual switches/firewalls) under a virtualised environment may not be easily identified, the virtual infrastructure should be depicted clearly. Furthermore, the procedures for ongoing operation, support and maintenance should also be aligned with the IT security requirements and strictly followed by respective parties.
- l) **Use valid licences.** It is necessary to ensure that licences are suitable and compatible with the virtualised environment. Review requirements for any licences needed in the virtualised environment.

3. Vulnerability and Policy Management

Security issues related to vulnerability and policy management may become worse in virtualised environment. Configurations should be properly managed and VM images should be effectively patched.

- a) **Update patches.** Keep the host OS and all guest OS partitions patched including VMs and VM appliances stored offline. For most cases, they must be brought online on a live machine to be patched. Consider to deploy advanced security tools that address the patching needs of offline VMs if applicable.
- b) **Vulnerability scanning.** Use vulnerability management tools to regularly scan the host OS and all guest OS partitions for vulnerabilities. Ensure correct configuration and updated patches are in place. The same checking should be extended to offline disk-based configurations even though they are not currently in use.
- c) **Protect the virtualisation image and configuration files.** Protect resources such as shared disks, VLANs and CPU resource allocation since VM images can be copied along with the data and applications they held. These images can be brought back online on an unsecured computer such that it is easy for an intruder to access contents or configuration files managed within the copied image.
- d) **Extend policies, practices and technologies to virtualised environment.** Manage, validate and control the virtual infrastructure in a way similar to the physical infrastructure. Monitoring and protecting each layer in the configuration are crucial to reduce the threat surface.
- e) **Disable all clipboard capabilities between VMs.** Security issues may arise as a result of clipboard behaviour, e.g. the system administrator might use the clipboard to copy and paste password. Transferring text objects, such as a password from one application to another, in any direction between the VM and the host OS is possible. VMs should be isolated so that it should not reveal any data from other VMs if a local VM was compromised.
- f) **Adhere strictly to a provisioning process and change management workflow.** As changes under virtualised environment (e.g. removing or duplicating a VM) can be fast and unnoticed, relevant IT processes and technologies should be in place to detect variance from a secure baseline and to enforce change management workflow.
- g) **Perform regular maintenance for VMs.** Long dormant VMs can require significant time and effort to patch and maintain, regular maintenance on VMs is recommended. The security level of a VM, such as security patch level or up-to-date of virus signature, should be checked before putting it online.

- h) **Security level review after restore.** Review the security level of the VM when it is fallen back to a previous restore point. Most VMs allow creating “snapshots” to save their states at different points of time. However, reverting a VM to a previous state may return to an unpatched and non-compliant state. A review should be performed to ensure the VM has reached the required security level before putting it online.

4. Intrusion Prevention and Protection

Traditional network security devices may not be able to inspect network traffic within a virtualised environment. Measures for intrusion prevention and protection should be enforced and extended.

- a) **Disable unnecessary hardware ports.** For any hardware port which is not in use, disable it on each VM. Communication ports like USB should be disabled if business justification does not present.
- b) **Plan for a network firewall for each VM or cluster of related VMs.** Configuring and installing a firewall for each VM allows a tighter level of control and higher granularity specific to the VM it is protecting. This protection should be "portable" with the VM when it is relocated.
- c) **Plan for additional VM-based IDS and IPS protection as needed.** If one VM is corrupted, the physical and logical proximity of multiple VMs may increase the rate of infection in wormlike attacks. Newer host-based IDS and IPS technologies can monitor the behaviour of applications as they execute, looking for signs of a compromised VM. IDS and IPS capabilities may be installed on each VM to protect all VMs simultaneously.
- d) **Protect online and offline VM configuration and policy files.** Secure any files and management tools that govern the configuration of VMM and VM resources from unauthorised access and modification. Protect these settings with tight access control and full auditing.
- e) **Detect and block unauthorised VM management sessions.** All VM management sessions should be logged. In security-sensitive deployments, these sessions should be monitored such that unauthorised sessions can be detected and then blocked at an early stage.
- f) **Protect offline disk-based VM images.** Offline disk-based VM images will be targets for attack and there is a potential of corruption. Protect these images with tight access control, full auditing and logging, as well as checksums or digital signatures to detect potential corruption or protect from unauthorised tampering.

5. Identity and Access Management

Managing user identity and access control may become complicated in a virtualised environment. Various restriction and control policies should be applied to protect against unauthorised access.

- a) **Enforce separation of duties (SOD).** Accounts and roles for security administration should be separated from other administrative activities. On each VM, consider to separate the administrative roles with respect to server, network, application and database as required on a physical server.
- b) **Secure the use of administrator accounts.** Apply proper access controls and security measures to protect administrator accounts on the host computer. Strong authentication should be considered. The “root” administrative access should be tightly managed with a process for check-out/check-in with full logging on activities performed.
- c) **Tighten the control on the starting and stopping of critical VMs.** Restrict that only authorised administrators can start or stop the process of critical VMs. It is to prevent critical VMs from being shut down or paused resulting in service suspension or compromise of data managed by dependent VMs.
- d) **Protect access to VM management tools.** Management tools, such as for VM migration or VM configuration, should be protected from unauthorised access.

6. Network Access Control

VMs being attached to the network should comply with the established security policy. Network access control (NAC) capabilities should be extended to VMs and remote clients to lower the risk when the VMs are connecting to the network.

- a) **Limit all network-based remote access.** All network-based remote access including administrative access should be limited when trying to access highly secured and trusted systems. The management interface should be protected by strong access control mechanisms. A best practice would be implementation of stateful firewall rules to control access to the network and ensure that guest OS network traffic is strictly prohibited.
- b) **Ensure secure guest-to-host and guest-to-guest communications.** The connections between guest-to-host and guest-to-guest should be encrypted and authenticated on secure layer, e.g. SSL, RDP over SSL. For guest-to-host communications, a dedicated and secure communication channel is recommended.
- c) **Ensure appropriate network segregation.** All management / control networks should be separated from other networks. There should be multi-layer protection on the administrative interfaces, e.g. with firewall control to limit only legitimate network traffic, and only accessible to authorised administrators. Access control or secure channel (e.g. VPN) should be used to restrict the access. Protected from unauthorised access.

7. Monitor and Audit

Monitoring and auditing in the virtualisation environment have important aspects in identifying and tracking attacks, misuse or any other security risks.

- a) **Security events should be captured on the VMM and every guest VM.** Examples of security-relevant events include the appearance and removal of VMs within each virtual server, as well as all administrative activities (e.g. changes to user access rights, modification to file permissions) of the host/parent partition and VMM.
- b) **Ensure VMs are conformed to the policy.** The security patch levels, configuration, security software of VMs should comply with the security requirements. Regular checking should be performed to identify and quarantine any non-compliant VMs.
- c) **Monitor the event log and security events.** Both the host machine and VMs should be monitored on a regular basis. These logs should be stored in a log vault if applicable for better security and auditing purposes. Additional monitoring and logging of all management interface access should be introduced.
- d) **Perform logging, audit and analysis of VMs.** Use appropriate tools to monitor both configuration changes and movement of VMs.
- e) **Remote access to VMM and its management console should be controlled and monitored.** Connection attempts from unauthorised or suspicious sources should be identified and investigated.
- f) **Consecutive failed transactions and attempts by operators or administrators should be analysed and followed up.** Transactions include unsuccessful log-in attempts, insufficient rights to access system files, failed to execute routine batch jobs should be identified, checked and followed up.